

Corpus Orientativo LGPD para Assistente RAG

Versao para projeto individual - Desenvolvendo Software com IA Generativa

Objetivo do corpus

Este documento foi preparado como corpus textual para um assistente RAG de apoio a desenvolvedores, analistas de produto e equipes pequenas que precisam localizar rapidamente conceitos e referencias da Lei Geral de Protecao de Dados Pessoais (LGPD). O conteudo e educativo e operacional, nao substitui parecer juridico, decisao de DPO nem consulta ao texto oficial atualizado.

Fontes de referencia usadas para estrutura do corpus: texto compilado da Lei 13.709/2018 no Portal do Planalto; materiais orientativos da Autoridade Nacional de Protecao de Dados (ANPD), especialmente guias sobre agentes de tratamento, encarregado, seguranca da informacao e legitimo interesse.

Como usar este corpus no projeto

O assistente deve responder com base neste corpus e citar a pagina consultada. Quando a pergunta mencionar artigo da LGPD, a tool `cite_article` ajuda a confirmar o artigo e reduzir alucinacoes sobre numeros legais.

1. Conceitos basicos da LGPD

A LGPD regula operacoes de tratamento de dados pessoais realizadas por pessoa natural ou juridica, de direito publico ou privado, inclusive em meios digitais. O foco da lei e proteger direitos fundamentais de liberdade, privacidade e livre desenvolvimento da personalidade.

Dado pessoal e a informacao relacionada a pessoa natural identificada ou identificavel. Exemplos praticos: nome, CPF, e-mail individual, telefone pessoal, endereco, identificador de dispositivo, imagem facial e historico de compras quando permite identificar uma pessoa.

Dado pessoal sensivel e uma categoria que exige cautela reforcada, pois pode causar maior risco de discriminacao ou dano. Inclui dados sobre origem racial ou etnica, conviccao religiosa, opiniao politica, filiacao sindical, saude, vida sexual, dado genetico ou biometrico vinculado a uma pessoa natural.

Tratamento e um conceito amplo: inclui coleta, producao, recepcao, classificacao, uso, acesso, reproducao, transmissao, distribuicao, processamento, arquivamento, armazenamento, eliminacao, avaliacao, controle, modificacao, comunicacao, transferencia, difusao ou extracao de dados.

2. Papeis dos agentes de tratamento

O controlador é o agente que toma as decisões referentes ao tratamento de dados pessoais. Em uma empresa, normalmente é a organização que define finalidade, meios essenciais e base legal do tratamento.

O operador realiza o tratamento em nome do controlador e conforme suas instruções. Um fornecedor de e-mail marketing, uma plataforma de armazenamento em nuvem ou um processador de pagamentos podem atuar como operadores dependendo do contexto contratual.

O encarregado ou DPO atua como canal de comunicação entre controlador, titulares e ANPD. Suas atividades incluem receber reclamações e comunicações dos titulares, prestar esclarecimentos, receber comunicações da autoridade nacional e orientar funcionários e contratados.

A definição de controlador e operador depende da situação concreta, e não apenas do nome usado no contrato. Para cada fluxo de dados, deve-se perguntar quem decide a finalidade, quem define os meios essenciais e quem executa instruções.

3. Principios do tratamento - Art. 6

O principio da finalidade exige proposito legitimo, especifico, explicito e informado ao titular. A equipe deve evitar coletar dados para uma finalidade vaga como melhorar servicos sem explicar o uso concreto.

O principio da adequacao exige compatibilidade entre o tratamento e a finalidade informada. Se o usuario forneceu e-mail para recuperar senha, usar o mesmo dado para campanhas promocionais exige avaliacao separada.

O principio da necessidade orienta minimizacao: tratar apenas dados pertinentes, proporcionais e nao excessivos. Em formularios, campos como CPF, data de nascimento e endereco devem ser justificados pela finalidade.

Transparencia, seguranca, prevencao, nao discriminacao e responsabilizacao exigem que a organizacao documente decisoes, implemente controles e seja capaz de demonstrar conformidade.

4. Bases legais para dados pessoais - Art. 7

O tratamento de dados pessoais comuns precisa estar vinculado a uma das hipóteses legais do art. 7. Consentimento é apenas uma das bases possíveis; nem sempre é a melhor, especialmente quando há obrigação legal ou contrato.

A execução de contrato pode justificar dados necessários para cumprir serviço solicitado pelo titular, como endereço para entrega ou dados de pagamento para cobrança. O uso deve permanecer limitado ao necessário para o contrato.

O cumprimento de obrigação legal ou regulatória pode justificar armazenamento de dados fiscais, registros contábeis e informações exigidas por lei. Mesmo nessa base, devem ser aplicados princípios de segurança, necessidade e retenção adequada.

O legítimo interesse pode ser utilizado em situações concretas, com avaliação de finalidade legítima, necessidade e balanceamento com direitos do titular. Não deve ser aplicado automaticamente como base genérica.

5. Consentimento - Arts. 8 e 9

O consentimento deve demonstrar manifestacao de vontade livre, informada e inequivoca do titular. Para fins praticos, a interface deve evitar caixas pre-marcadas, textos escondidos e termos excessivamente genericos.

Quando o consentimento for por escrito, deve aparecer em clausula destacada das demais. Em sistemas digitais, recomenda-se registrar versao do texto, data, horario, finalidade, canal e identificador do titular.

O titular deve ter acesso facilitado a informacoes sobre finalidade, forma, duracao, identificacao do controlador, contatos, compartilhamento, responsabilidades dos agentes e seus direitos.

Se o consentimento for revogado, a equipe deve avaliar se existe outra base legal aplicavel. Caso contrario, o tratamento relacionado a esse consentimento deve cessar, salvo conservacoes permitidas por lei.

6. Dados sensíveis - Art. 11

Dados sensíveis exigem governança mais rigorosa, pois aumentam riscos para o titular. Antes de coletar, a equipe deve perguntar se o dado é indispensável para a funcionalidade ou se existe alternativa menos invasiva.

O consentimento para dado sensível deve ser específico e destacado, para finalidades específicas. Em várias situações, outras hipóteses podem ser aplicáveis, como cumprimento de obrigação legal, tutela da saúde, proteção da vida ou exercício regular de direitos.

Dados biométricos para autenticação devem ser tratados com cautela: requerem segurança reforçada, limitação de finalidade, políticas de retenção e avaliação de impacto quando houver risco relevante.

Em produtos de tecnologia, qualquer campo que revele saúde, religião, opinião política, biometria ou origem racial deve passar por revisão antes do deploy.

7. Crianças e adolescentes - Art. 14

O tratamento de dados de crianças e adolescentes deve observar o melhor interesse. Isso exige linguagem clara, coleta minimizada, controles de segurança e revisão cuidadosa de finalidades comerciais.

Para crianças, a LGPD exige consentimento específico e em destaque por pelo menos um dos pais ou responsável legal, salvo exceções previstas para proteção da criança ou contato com responsável.

Aplicações direcionadas a público infantil devem evitar perfis excessivos, publicidade comportamental invasiva e compartilhamento desnecessário com terceiros.

Em uma análise de produto, a equipe deve identificar se o serviço é dirigido a menores ou se há probabilidade real de uso por menores.

8. Direitos do titular - Art. 18

O titular pode solicitar confirmacao de tratamento, acesso aos dados, correcao de dados incompletos ou desatualizados, anonimizacao, bloqueio ou eliminacao de dados desnecessarios ou tratados em desconformidade.

Tambem pode solicitar portabilidade, informacao sobre compartilhamento, informacao sobre a possibilidade de nao consentir, revogacao do consentimento e revisao de decisoes tomadas unicamente com base em tratamento automatizado.

Para operacionalizar esses direitos, a aplicacao deve ter canal de contato, triagem, verificacao de identidade, registro de solicitacoes, prazos internos e procedimento para responder ou justificar impossibilidade.

Nao basta ter uma politica de privacidade; e necessario que a equipe consiga localizar dados e executar a resposta ao titular na pratica.

9. Retencao e eliminacao - Arts. 15 e 16

O termino do tratamento pode ocorrer quando a finalidade foi alcançada, quando o periodo necessario terminou, quando ha revogacao do consentimento ou por determinacao da ANPD.

Apos o termino, dados pessoais devem ser eliminados, salvo conservacao para cumprimento de obrigacao legal ou regulatoria, estudo por orgao de pesquisa, transferencia a terceiro observados requisitos legais ou uso exclusivo com anonimizacao.

Uma boa politica de retencao define prazos por categoria de dado e finalidade. Exemplo: dados de suporte podem ter prazo menor que dados fiscais, porque a justificativa legal e operacional e diferente.

Backups tambem devem ser considerados. A eliminacao imediata em backups pode nao ser tecnicamente possivel, mas deve existir prazo de sobrescrita e controle de restauracao.

10. Seguranca da informacao - Art. 46

Os agentes de tratamento devem adotar medidas tecnicas e administrativas para proteger dados pessoais contra acessos nao autorizados e situacoes acidentais ou ilicitas de destruicao, perda, alteracao, comunicacao ou difusao.

Medidas tecnicas incluem controle de acesso, autenticacao forte, criptografia em transito, criptografia ou hashing adequado quando aplicavel, logs, segmentacao, backups, gestao de vulnerabilidades e revisao de permissoes.

Medidas administrativas incluem politicas internas, treinamento, contratos com fornecedores, classificacao de dados, plano de resposta a incidentes, gestao de riscos e registro de decisoes de tratamento.

Para pequenos agentes, recomenda-se comecar pelo basico bem feito: senhas fortes, MFA, atualizacoes, backups, controle de acesso minimo necessario e procedimento claro para incidentes.

11. Incidentes de segurança - Art. 48

O controlador deve comunicar a ANPD e o titular quando um incidente de segurança puder acarretar risco ou dano relevante aos titulares. A avaliação deve considerar tipo de dado, volume, titulares afetados, possibilidade de dano e medidas de mitigação.

Um incidente pode envolver vazamento, acesso indevido, perda, destruição, alteração não autorizada ou indisponibilidade que afete dados pessoais. Nem todo evento exige comunicação externa, mas todo evento relevante deve ser registrado e avaliado.

A comunicação deve conter informações como natureza dos dados afetados, titulares envolvidos, medidas técnicas e de segurança utilizadas, riscos relacionados, motivos de eventual demora e medidas adotadas ou a serem adotadas.

Equipes de desenvolvimento devem manter logs e trilhas de auditoria suficientes para reconstruir o evento sem expor ainda mais dados pessoais.

12. Relatório de impacto e registros - Arts. 37 e 38

O registro das operações de tratamento ajuda a demonstrar conformidade e facilita respostas a titulares. Um registro mínimo deve conter finalidade, categorias de dados, base legal, titulares, compartilhamentos, retenção e medidas de segurança.

A ANPD pode determinar que o controlador elabore relatório de impacto à proteção de dados pessoais. Na prática, relatórios de impacto são recomendáveis em tratamentos de alto risco, dados sensíveis, grande escala ou monitoramento sistemático.

Um relatório de impacto descreve processos de tratamento, riscos aos direitos dos titulares, medidas de mitigação e salvaguardas. Não é apenas documento jurídico: depende de informações técnicas sobre arquitetura, acessos e fluxos de dados.

Para um MVP, a equipe pode iniciar com um inventário simples de dados e evoluir para DPIA/RIPD nos fluxos mais críticos.

13. Legítimo interesse - Art. 10

O legítimo interesse exige análise concreta. A pergunta central não é apenas se a empresa tem interesse, mas se o interesse é legítimo, se o tratamento é necessário e se não prevalecem direitos e liberdades fundamentais do titular.

Boas práticas incluem documentar um teste de balanceamento, oferecer transparência reforçada, permitir oposição quando aplicável e reduzir dados ao mínimo necessário.

Exemplos possíveis podem envolver prevenção à fraude, segurança da informação, melhoria moderada de serviço ou comunicação com clientes existentes, sempre dependendo do contexto.

Legítimo interesse não deve ser usado para dados sensíveis como atalho, nem para substituir consentimento quando a expectativa do titular for incompatível com a finalidade.

14. Checklist para equipes de produto

Antes de criar uma feature, identifique: quais dados pessoais serão coletados, de quem, para qual finalidade, por qual base legal, por quanto tempo, com quem serão compartilhados e quais controles de segurança existem.

Evite coletar dados apenas porque podem ser úteis no futuro. A coleta deve estar associada a uma finalidade atual, clara e documentada.

Garanta transparência na interface: políticas, avisos curtos, telas de consentimento quando necessário e linguagem compreensível.

Planeje direitos do titular desde o início. Se a equipe não consegue localizar, corrigir ou excluir dados quando necessário, o risco operacional aumenta.

15. Perguntas de teste para RAG

1. Posso armazenar CPF de usuarios para emitir nota fiscal? Qual base legal pode justificar isso?
2. Quais principios devo observar ao criar um formulario de cadastro?
3. O que devo fazer se houver vazamento de e-mails e telefones de clientes?
4. Quando o consentimento e necessario e como devo registrá-lo?
5. Quais direitos o titular pode exercer sobre seus dados?
6. O que muda quando trato dados de criancas ou dados sensiveis?
7. Que medidas de seguranca sao recomendadas para um pequeno agente de tratamento?

Tabela operacional de decisao

Situacao	Verificacao inicial	Referencia
Coleta de CPF	Finalidade concreta, necessidade, base legal e retencao	Arts. 6, 7, 16
Marketing por e-mail	Expectativa do titular, consentimento ou legitimo interesse documentado	Arts. 7, 8, 10
Dado de saude/biometria	Hipotese especifica para dado sensivel e seguranca reforcada	Art. 11
Crianças	Melhor interesse e consentimento do responsavel quando exigido	Art. 14
Incidente	Risco ou dano relevante, comunicacao e mitigacao	Art. 48
Direitos do titular	Canal, verificacao de identidade, prazo e resposta documentada	Art. 18

Nota final: use este documento para demonstracao de busca e apoio operacional. Para decisao real, consulte texto legal atualizado, politicas internas e responsavel juridico/DPO.